

공개 기술 백서

ODRE PQC v0.2.9

Application-Embedded Post-Quantum Security Boundary

개발 · 보안 진화 · 위협 검증 · 교차 플랫폼 증거

PUBLIC TECHNICAL WHITEPAPER

2026년 9월

목차

01	개발·보안 진화 v0.1.1에서 v0.2.9까지
02	위협 모델과 보안 검증 Replay · Sequence · Native Identity
03	플랫폼별 검증 Windows Server 2022 · Ubuntu 24.04 LTS
04	Artifact와 증거 봉인 Wheel · Runtime · 근거 보고서
05	결론 관측된 개선 계보와 최종 확인 대상

본 문서는 제품 개요와 아키텍처 설명을 별도 문서로 분리하고, 개발·보안 진화와 실행 증거에 집중한다.

이 문서는 제품 개요와 제품 아키텍처를 다루지 않는다. 해당 내용은 별도 문서인 [ODRE PQC v0.2.9 제품 개요 및 보안 아키텍처](#)에서 다룬다. 본 기술백서는 ODRE PQC의 개발·보안 진화, 위협 모델별 검증, 플랫폼별 실행 결과, 봉인 Artifact와 근거 자료의 추적 관계를 기록한다.

1. 개발·보안 진화

1.1 v0.1.1: 보호 경로 평문 우회 차단

v0.1.1 보고서는 직전 감사에서 [PQC-001 HIGH](#)로 분류된 보호 경로 평문 우회 문제와 그 수정 결과를 기록한다. 보안 런타임이 실패한 상황에서 보호 경로가 Consumer Handler까지 도달할 수 있다면, 암호 경계가 실패했음에도 애플리케이션 기능이 실행되는 구조가 된다.

v0.1.1은 [/secure/*](#) 보호 정책을 Fail-Closed로 고정하고 보안 실패 시 Handler 우회를 차단했다. v0.1.1 Wheel을 대상으로 수행된 검증에서는 다음 항목이 기록됐다.

- Wheel SHA-256: [627AF68632D5C99481849CB1C43497381267CCE426F3A5DA9752B069C36D37E6](#)
- RECORD 무결성: 20/20
- Import Safety 확인
- [install\(app\)](#) Plugin API 확인
- 보호 경로 정책: Fail-Closed
- 보안 실패 시 Consumer Handler 실행: 0
- 공개 경로와 보호 경로의 격리 확인
- Resource Lifecycle·Cleanup 확인

이 수정은 이후 버전의 기본 보안 계약이 됐다. 후속 버전에서는 단순히 같은 시험을 반복하는 데 그치지 않고 Replay, Request Binding, Native Runtime Trust, Crash Recovery와 Platform-specific Attack으로 검증 범위를 확장했다.

1.2 v0.1.2: 기능 검증 통과 뒤 Clean-room 공격 시험에서 드러난 세 가지 결함

v0.1.2에는 서로 목적이 다른 두 보고서가 남아 있다. 제품 검증 보고서는 설치 API, Fail-Closed 경로, 회전 정책, 보안 데이터베이스 마이그레이션, 종료 시 Drain, 고객용 명령행 진단과 클라이언트 왕복을 점검했다. 이 보고서에서는 전체 시험 38/38, 설정·회전 오용 시나리오 37/37, 시작·종료 주기 10회를 통과했다고 기록했다. 대상 Wheel의 SHA-256은 [59A562C789B28C05B309AAD0BC51511D9BD16D84A783021F1598A8AF21B4F06D](#)이었다.

그러나 동일 SHA-256의 Wheel을 새 Python 3.12 가상환경에 해시 고정 의존성으로 설치한 별도 Clean-room 재검증은 보안 공격 시험 20개 중 17개만 통과했다. 설치, 실제 PQC 정상 경로, 클라이언트 왕복, 패키지 RECORD 30/30, 자원 수명주기는 통과했지만 공격 관점에서 세 결함이 재현됐다. 따라서 기능·회귀 시험의 통과를 공격 표면 전체의 통과로 확대할 수 없었다.

1.2.1 F-001: Sequence Gap 수락

시험은 Sequence 5를 의도적으로 보류한 상태에서 Sequence 6을 전송했다. 기대 동작은 간격이 생긴 요청을 거부하고 보호 Handler를 실행하지 않는 것이었다. 실제 관측에서는 Sequence 6이 HTTP 200으로 수락됐고 보호 Handler 실행 횟수가 3회에서 4회로 증가했다.

이 결함의 핵심은 단순 중복 Replay가 아니라 순서의 연속성이다. 중복 번호만 차단하고 현재 번호보다 큰 값을 허용하면, 공격자는 중간 요청을 건너뛰거나 순서를 교란해도 세션을 전진시킬 수 있다. 따라서 Sequence 검증은 **미사용 값인가**만 확인해서는 안 되고 **정확히 다음 값인가**를 원자적으로 확인해야 한다.

1.2.2 F-002: Oversized Response 판정 전 Handler 실행

보호 Handler가 제한을 초과하는 응답을 생성하도록 구성된 시험에서 외부 응답은 HTTP 503으로 닫혔고 평문 유출은 관측되지 않았다. 그러나 응답 크기를 거부하기 전에 Handler가 한 번 실행됐다.

보안 경계에서 중요한 것은 최종 네트워크 응답만이 아니다. Handler가 데이터베이스 변경, 외부 호출, 파일 기록 같은 부작용을 수행할 수 있기 때문이다. 출력 단계에서 거부하더라도 애플리케이션 부작용은 이미 발생할 수 있으므로, 지원하지 않는 응답 계약은 Handler 진입 전에 식별돼야 한다.

1.2.3 F-003: Unsupported Streaming 판정 전 Handler 실행

Streaming·SSE·Iterator·WebSocket 계열은 당시 보호 응답 계약에서 지원하지 않는 유형이었다. 시험 결과 외부 응답은 HTTP 503으로 닫히고 평문은 유출되지 않았지만, 지원 여부를 판정하기 전에 Handler가 한 번 실행됐다. F-002와 마찬가지로 Fail-Closed의 위치가 너무 늦었다는 문제다.

v0.1.2 Clean-room 보고서는 이 세 결함을 감사 도중 수정하지 않았다. 실패 상태와 관측값을 그대로 보존했고, 수정 및 폐쇄 확인은 v0.1.3의 대상이 됐다.

1.3 v0.1.3: Strict Sequence와 Pre-handler Contract Enforcement

v0.1.3은 v0.1.2에서 확인된 세 결함을 보안 경계의 진입 순서 자체를 바꾸는 방식으로 폐쇄했다.

- Sequence는 Gap·Rollback·Duplicate를 모두 거부하도록 강화했다.
- Oversized 또는 크기를 사전에 제한할 수 없는 보호 응답 계약은 Handler 실행 전에 거부했다.
- Streaming·SSE·Iterator·WebSocket은 미지원 상태에서 Handler 실행 전에 차단했다.

새 Python 3.12 가상환경에서 `--require-hashes`로 설치한 Clean-room 재검증은 설치된 `site-packages` Wheel을 직접 사용했다. 실제 OpenSSL 3.5.8의 ML-KEM-768과 ML-DSA-65 연산을 정상 경로에 사용했으며 Mock 암호 구현으로 대체하지 않았다.

재검증 결과는 다음과 같다.

검증 영역	관측 결과
보안 공격 시험	20/20
보안 실패 시 Handler 실행	0
잘못된 구성 시험	6/6
Wheel RECORD	31/31
신규 Critical·High·Medium	0/0/0

특히 Strict Sequence 시험에서는 Gap·Rollback·Duplicate 요청이 모두 거부됐고 보호 Handler 실행은 0이었다. Oversized·Unbounded Response와 미지원 Streaming 계열도 Handler 이전에 거부됐으며 평문 유출은 관측되지 않았다. 감사 대상 Wheel의 SHA-256은 `EEA164895F835478441465112AAEEF8F6768740FFE2908BBE7CD53298D934D12`였다.

1.4 v0.1.4: 관측 인터페이스 추가와 기존 보안 계약의 비회귀 확인

v0.1.4의 변화는 상태 관측 기능을 추가하면서도 기존 보호 경계가 약화되지 않았는지 확인하는 데 초점이 있었다. 상태 기능은 제품 시험 15개와 실제 Runtime 독립 확인 4개로 검증됐고, v0.1.3에서 확립한 보안 시험 41개는 변경 없이 다시 통과했다. 개발 단계의 결함 결과는 56/56으로 기록됐다.

Clean-room 재검증은 다음 조건에서 수행됐다.

- 새 Python 3.12 가상환경과 해시 고정 의존성
- 설치된 Wheel에서 실행
- 실제 OpenSSL Runtime 사용
- 실제 ML-KEM-768·ML-DSA-65 정상 경로
- 보안 공격 시험 20/20
- 잘못된 구성 시험 6/6
- Handler 우회 0
- RECORD 32/32
- 상태 조회에 의한 상태 변경 0
- 상태 출력의 Secret Leakage 0
- 자동 Classical Downgrade 0
- 신규 Critical·High·Medium 0/0/0

대상 Wheel의 SHA-256은 [19EF222083C15D89E63B49A08D62EFEF480F3B82443839C900B6DAE425B13E54](#)였다. v0.1.4는 기능을 추가한 뒤 단순히 신규 기능만 시험하지 않고, v0.1.2에서 실패했던 Sequence와 Pre-handler 차단 조건을 후속 버전에서도 다시 확인했다는 점에 의미가 있다.

1.5 v0.1.2~v0.1.4 개선 계보 요약

버전	발견·변경 항목	공격 가능성 또는 회귀 위험	수정 구조	재검증
v0.1.2	Sequence Gap 수락	요청 순서 교란 뒤 세션 전진	Strict next-sequence 검증 필요 확인	Clean-room 17/20, 실패 보존
v0.1.2	Oversized Response 판정 전 Handler 실행	외부 응답 차단 전 애플리케이션 부작용 가능	Pre-handler 응답 계약 판정	v0.1.3에서 Handler 실행 0
v0.1.2	Unsupported Streaming 판정 전 Handler 실행	미지원 유형에서도 부작용 가능	미지원 유형 Pre-handler 거부	v0.1.3에서 Handler 실행 0
v0.1.3	세 결함 수정	수정이 정상 경로·패키징을 깨뜨릴 위험	Strict Sequence와 Pre-handler Enforcement	공격 시험 20/20, 구성 6/6, RECORD 31/31
v0.1.4	상태 관측 기능 추가	조회가 상태를 바꾸거나 비밀을 노출할 위험	읽기 전용·비밀 비노출 상태 계약	상태 시험 15+4, 기존 보안 시험 41/41, RECORD 32/32

1.6 v0.2.4 → v0.2.5: Ubuntu Native ABI 결함

Windows 검증을 통과한 v0.2.4를 Ubuntu 실제 환경에서 다시 검증하는 과정에서 Linux Shim의 [odre_shutdown](#) Export 누락이 확인됐다. 이 사례는 동일한 Python 통합 표면을 갖더라도 Native Runtime ABI가 플랫폼마다 별도로 검증돼야 함을 보여준다.

v0.2.5에서는 다음을 수정·검증했다.

- Ubuntu Shim의 기대 Export 15개와 실제 Export 15개 일치
- [odre_shutdown](#) Export 존재 확인

- Double Shutdown과 Startup→Shutdown→Startup 수명주기
- 5/5 반복 Cycle
- File Descriptor Delta 0
- 종료 후 Shim Unmap 확인
- OpenSSL 3.5.8 Runtime Identity 확인
- 실제 ML-KEM-768·ML-DSA-65 실행 확인

그러나 v0.2.5 표적 재감사에서 추가 High 1건과 Medium 2건이 확인되면서 Release Blocking 상태가 유지됐다. 해당 결함의 원인과 수정은 v0.2.6 계보에서 다룬다.

1.7 v0.2.6: Native Trust·TOCTOU·FD Identity 강화

v0.2.6 자료는 Blind Static Audit, Targeted Reproduction, Confirmed Root Cause, Static-to-Dynamic Classification, Remediation, Final Multi-AI Audit으로 분리돼 있다. 이는 정적 의심점을 곧바로 결함으로 선언하지 않고, 실제 공격 Harness로 재현한 뒤 제품 결함과 비재현 후보를 분류하는 과정이다.

핵심 보강 영역은 다음과 같다.

- Hash 확인 대상과 실제 로드 객체 사이의 TOCTOU 차단
- 파일 경로가 아니라 실제 FD·Inode Identity를 이용한 결함
- Native Provider와 Dependency Search 경로 검증
- 교체·재사용·경로 바꿔치기 공격에서 Verified Object와 Loaded Object의 동일성 확인
- 수정 뒤 양쪽 플랫폼 회귀 시험

v0.2.6 공식 Wheel SHA-256은 [4756FC9B219DAB4E2BF9C90FA066CFFD0D5DEA94FEF03DCE0B18DED55E5A7C7A](#)로 기록돼 있다.

1.8 v0.2.8 → v0.2.9: F-028-01과 부모 객체 교체 방어

v0.2.8에서 [F-028-01](#)이 확인됐다. 취약한 초기화 경로는 승격 전 [Path.resolve\(\)](#) 결과가 일시적인 Root Symlink의 영향을 받을 가능성이 있었다.

v0.2.9은 Linux에서 신뢰된 Parent Directory Chain을 [O_DIRECTORY | O_NOFOLLOW](#)로 열어 유지하고, Staging Directory Identity를 잠근 뒤 Parent-dirfd 상대 [renameat2\(..., RENAME_NOREPLACE\)](#)로 승격하도록 수정했다. 승격된 Directory의 ([st_dev](#), [st_ino](#))가 Staging Object와 동일한지도 다시 확인한다. 필요한 Primitive나 Identity Proof를 사용할 수 없으면 초기화는 진행되지 않는다.

표적 공격 결과는 다음과 같다.

- Trials: 600
- Symlink Swaps: 1,212,203
- Exit Distribution: 성공 278 / 안전한 중단 322
- Object·Path Misbinding: 0
- External Path Persistence: 0
- External File Mutation: 0
- Secret Leakage: 0

- Partial Promoted State: 0

후속 전체 감사에서는 별도의 Late-promotion Parent-object Attack 600회가 다시 실행됐으며, 600/600 상태에서 초기화가 Fail-Closed로 종료되고 Object/Path Misbinding과 External Secret State가 0으로 관측됐다.

2. 위협 모델과 보안 검증

이 장은 다음 항목을 각각 공격 전제, 입력, 기대 동작, 실제 관측값, 근거 보고서로 분해해 작성한다.

1. Replay·Sequence 경쟁
2. 요청·응답 변조
3. 교차 세션·교차 경로 공격
4. Malformed·Oversized Input
5. HTTP Smuggling 형태
6. Fuzz·Soak·Load
7. TOCTOU·FD·Inode Identity
8. Symlink·Junction·Reparse 공격
9. Loaded-object Identity
10. Provider·Dependency·Config Injection
11. Worker Collision·Concurrent Init
12. Crash·Restart·Shutdown Lifecycle
13. Stale Session·Lease·Status 재사용

2.1 Replay·Sequence 경쟁 - 확인된 최종 관측값

플랫폼	중복 요청	시퀀스당 수락	Double Handler Execution
Windows Server 2022	1,280	정확히 1회	0
Ubuntu 24.04 LTS	2,880	정확히 1회	0

Replay 시험의 판단 대상은 오류 응답의 존재만이 아니다. 동일 Sequence가 경쟁 상태로 도착했을 때 애플리케이션 Handler가 두 번 실행되지 않았는지를 별도로 계측했다.

2.2 Native Loaded-object Identity - 확인된 최종 관측값

Windows에서는 실제 Provider·WinDLL Load 3,000회, 성공한 Atomic Replacement 1,062회, Junction 생성·제거 3,000회를 관측했다. Untrusted DLL Load, Untrusted Dependency Load, Reparse Bypass, Verified-vs-loaded Identity Mismatch는 모두 0이었다.

Ubuntu에서는 Atomic File·Parent·Symlink Swap, Unsafe Parent, Dependency·Provider·Module·Engine·Config Injection, FD·Inode Identity와 50+50 Lifecycle Cycle이 검증 범위에 포함됐다.

3. 플랫폼별 검증

3.1 Windows Server 2022

- Windows Server 2022 AMD64
- CPython 3.12.10
- Hash-locked Offline Install
- init · Second-init Protection · doctor · verify · status
- 실제 ML-KEM-768 · ML-DSA-65와 Hybrid Handshake
- Request Semantic Binding · Response Metadata Boundary
- ACL Trust · Status Authentication · Shutdown Resource Lifetime
- Forced Termination · Second-crash Recovery

3.2 Ubuntu 24.04 LTS

- Ubuntu 24.04.4 LTS AMD64
- CPython 3.12.3
- Hash-locked Offline Install
- init · Second-init · doctor · Negative Doctor · verify · status
- 실제 ML-KEM-768 · ML-DSA-65와 Hybrid Handshake
- Admission Fuzz · Malformed · Oversized Input
- HTTP Smuggling Shape · WebSocket Fail-Closed
- Native Trust · Symlink · Parent Swap · FD/Inode Identity
- Graceful Shutdown · Restart · SIGKILL · Crash Recovery

4. Artifact와 증거

4.1 봉인 Wheel

- 파일: [odre_pqc-0.2.9-py3-none-any.whl](#)
- SHA-256: [A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697](#)
- RECORD: 45/45 Hashed Entry 확인
- Package · Runtime Version: 0.2.9 일치
- 감사 시작 · 종료 SHA-256 동일

4.2 Native Runtime Archive

- Windows Runtime SHA-256: [826303E72A76B10041D26113F465ADD8960825C71F50722D6792174E73F9D12C](#)
- Ubuntu Runtime SHA-256: [EFAD16698203371D07F25B429F6731B9C0954EEBF5B58A0024789EF0611A78D1](#)

4.3 근거 보고서 대응표 - 1차

기술백서 영역	주요 근거 보고서
v0.1.1	ODRE PQC v0.1.1 - Independent Audit Evidence Log
v0.1.2~v0.1.4	각 Version · Clean-room Reverification Report
v0.2.0	v0.2.0_FINAL_REPORT.md
v0.2.1	v0.2.1_CUSTOMER_ZERO_CONFIG_BOOTSTRAP_REPORT.md, v0.2.1_FINAL_AUDIT_REPORT.md
v0.2.5	v0.2.5_FINAL_REPORT.md, v0.2.5_REMEDIATION_HISTORY.md
v0.2.6	Blind Static · Targeted Repro · Root Cause · Remediation · Multi-AI Reports
v0.2.7	Independent Audit · Remediation Reports
v0.2.8	F-027-01 · RC03 · F-028-01 · Final Release Audit Reports
v0.2.9	F-028-01 Targeted Remediation · Full Development Security Audit

4.4 감사 Harness 문제와 제품 결함의 분리

최종 감사에서 확인된 6개의 Harness 문제는 제품 결함과 분리해 보존됐다. 시험 Fixture와 Binding을 수정한 뒤 제품 Byte를 바꾸지 않고 관련 Gate를 다시 실행했다. 기술백서에서는 Harness 오류를 제품 성공이나 제품 실패로 자동 해석하지 않고, 수정 · 재실행된 근거를 함께 제시한다.

5. 결론

ODRE PQC의 보안 개선은 단일 시점의 시험 통과가 아니라, 실패한 시험을 보존하고 공격 원인을 다음 버전의 구조 변경으로 연결한 반복 과정이었다. v0.1.1에서는 보호 경로의 평문 우회를 차단했고, v0.1.2의 Clean-room 공격 시험에서는 Sequence Gap과 Handler 이전 검증 순서의 결함을 확인했다. v0.1.3은 Strict Sequence와 Pre-handler Contract Enforcement로 이를 폐쇄했으며, v0.1.4는 상태 관측 기능을 추가한 뒤 기존 보안 계약의 비회귀를 확인했다.

후속 계열에서는 검증 범위를 Python 통합 경계에서 Native Runtime과 운영체제별 객체 신뢰 경계로 확대했다. Ubuntu ABI 누락, 파일 검증과 실제 로드 객체 사이의 TOCTOU, FD · Inode Identity, Symlink · Junction · Reparse, Provider · Dependency · Config Injection, Crash · Restart · Shutdown 수명주기를 별도의 공격 조건으로 다뤘다. v0.2.9의 붕괴 Wheel은 Windows Server 2022와 Ubuntu 24.04 LTS에서 동일 SHA-256을 유지한 채 재검증됐다.

최종 확인 대상은 `odre_pqc-0.2.9-py3-none-any.whl`이며 SHA-256은 `A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697`이다. Wheel RECORD 45/45, 감사 시작 · 종료 Artifact 동일성, 실제 OpenSSL 3.5.8 Runtime, ML-KEM-768, ML-DSA-65, Hybrid Handshake, Replay 경쟁, Native Loaded-object Identity와 수명주기 시험 결과가 근거 자료에 연결된다.